Penetration Test Report -- Juice_Shop

Engagement : Juice_Shop

Generated on : 2026-09-11T15:17:30.455484+00:00

Executive Summary

This engagement identified 8 analyst-validated finding(s): 2 medium, 4 low, 2 info. Critical and high severity findings should be prioritized for remediation (see dedicated section).

Engagement Scope

Authorized targets: 127.0.0.1

Methodology

This penetration test was conducted using a manual, low-aggression methodology, assisted by automated tooling (Nmap, Nuclei, ffuf) whose output was correlated, scored, and individually reviewed by a human analyst before inclusion in this report. No finding is included without explicit analyst validation.

Technical Findings

[Medium] Endpoint Prometheus /metrics accessible sans authentification

Target: 127.0.0.1 | Severity: Medium | Risk score: 5.48/10 (medium)

CWE: CWE-200 | MITRE ATT&CK: T1592

Une page de metriques Prometheus est accessible publiquement sur http://127.0.0.1:3000/metrics. L'exposition de metriques d'observabilite revele des informations internes (versions, chemins, compteurs d'erreurs, parfois noms d'hotes et variables d'environnement) utiles pour cartographier l'application avant exploitation.

Remediation:

Restreindre /metrics aux reseaux d'administration (filtrage IP, mTLS ou reverse-proxy avec authentification) et supprimer cet endpoint du meme port que l'application utilisateur.

Command used:

```
nuclei -target 127.0.0.1:3000 -severity info,low,medium,high,critical -jsonl -silent -etags dos,intrusive
```

Evidence (source excerpt): "template-id":"prometheus-metrics"

[Medium] Politique CORS permissive (origine generique autorisee)

Target: 127.0.0.1 | Severity: Medium | Risk score: 5.48/10 (medium)

CWE: CWE-942

La reponse HTTP du service sur le port 3000 renvoie un en-tete Access-Control-Allow-Origin avec la valeur joker, y compris sur les reponses OPTIONS listant les methodes autorisees. Une politique CORS ouverte permet a n'importe quel site de lire les reponses de l'application au nom d'un utilisateur authentifie si des cookies ou identifiants sont envoyes.

Remediation:

Remplacer la valeur joker par une liste blanche d'origines de confiance, valider l'en-tete Origin cote serveur et n'autoriser les identifiants (Access-Control-Allow-Credentials) qu'avec des origines explicitement approuvees.

Command used:

```
nmap -T3 -Pn -sV -p 3000 -oX - 127.0.0.1
```

Evidence (source excerpt): Access-Control-Allow-Origin

[Low] Documentation Swagger / OpenAPI publique

Target: 127.0.0.1 | Severity: Low | Risk score: 4.52/10 (medium)
CWE: CWE-200 | MITRE ATT&CK: T1592

Un fichier de specification Swagger est accessible publiquement (http://127.0.0.1:3000/api-docs/swagger.yaml). Il expose l'inventaire complet des routes, parametres et schemas de l'API, ce qui facilite la decouverte d'endpoints non documentes ou mal proteges et la construction de requetes ciblees.

Remediation:

Desactiver l'exposition publique de la specification OpenAPI en production, ou la proteger par authentification et la limiter aux environnements de developpement.

Command used:

```
nuclei -target 127.0.0.1:3000 -severity info,low,medium,high,critical -jsonl -silent -etags dos,intrusive
```

Evidence (source excerpt): "matched-at":"http://127.0.0.1:3000/api-docs/swagger.yaml"

[Low] robots.txt revelant le repertoire /ftp

Target: 127.0.0.1 | Severity: Low | Risk score: 4.16/10 (medium)
CWE: CWE-200 | MITRE ATT&CK: T1083

Le fichier robots.txt est present et son contenu extrait par Nuclei expose une entree disallow pointant vers /ftp. Ce type de directive indique aux robots d'indexation un chemin que le proprietaire souhaite masquer, mais ne protege en rien l'acces direct : cela guide un attaquant vers un repertoire potentiellement sensible.

Remediation:

Ne pas utiliser robots.txt comme mecanisme de dissimulation. Supprimer le contenu du repertoire /ftp s'il ne doit pas etre servi, ou le proteger par authentification et controle d'acces cote serveur.

Command used:

```
nuclei -target 127.0.0.1:3000 -severity info,low,medium,high,critical -jsonl -silent -etags dos,intrusive
```

Evidence (source excerpt): "extracted-results":["/ftp"]

[Low] HSTS non active sur le service web

Target: 127.0.0.1 | Severity: Low | Risk score: 4.52/10 (medium)
CWE: CWE-319

L'analyse Nuclei indique l'absence de l'en-tete Strict-Transport-Security sur http://127.0.0.1:3000. Sans HSTS, un utilisateur peut etre redirige vers une connexion non chiffree lors d'une attaque de type downgrade ou interception, ce qui expose les cookies de session.

Remediation:

Activer HTTPS avec un certificat valide et renvoyer l'en-tete Strict-Transport-Security avec un max-age suffisant (ex. 31536000) et includeSubDomains.

Command used:

```
nuclei -target 127.0.0.1:3000 -severity info,low,medium,high,critical -jsonl -silent -etags dos,intrusive
```

Evidence (source excerpt): "matcher-name":"strict-transport-security"

[Low] En-tete HTTP obsolete Feature-Policy encore utilise

Target: 127.0.0.1 | Severity: Low | Risk score: 3.86/10 (medium)
CWE: CWE-477

L'en-tete de reponse Feature-Policy est encore emis (valeur 'payment self'). Cet en-tete est deprecie et remplace par Permissions-Policy : selon les navigateurs, la restriction de fonctionnalites peut devenir inoperante, reduisant la defense en profondeur contre l'abus de fonctionnalites navigateur.

Remediation:

Migrer vers Permissions-Policy (ex. permissions-policy: payment=(self)) et supprimer l'en-tete Feature-Policy devenu obsolete.

Command used:

```
nuclei -target 127.0.0.1:3000 -severity info,low,medium,high,critical -jsonl -silent -etags dos,intrusive
```

Evidence (source excerpt): "extracted-results":["payment 'self'"]

[Info] En-tetes de securite HTTP absents

Target: 127.0.0.1 | Severity: Info | Risk score: 2.3/10 (low)

CWE: CWE-693

Nuclei signale l'absence de plusieurs en-tetes de securite sur http://127.0.0.1:3000, notamment la Content-Security-Policy. L'absence de CSP augmente l'impact d'une eventuelle injection de contenu (XSS) puisqu'aucune restriction de sources de scripts n'est imposee par le navigateur.

Remediation:

Ajouter une Content-Security-Policy restrictive (pas de 'unsafe-inline', sources de scripts limitees), ainsi que les autres en-tetes manquants : Referrer-Policy, Permissions-Policy, X-Permitted-Cross-Domain-Policies et COOP/COEP/CORP.

Command used:

```
nuclei -target 127.0.0.1:3000 -severity info,low,medium,high,critical -jsonl -silent -etags dos,intrusive
```

Evidence (source excerpt): "matcher-name":"content-security-policy"

[Info] Fichier security.txt exposant un contact interne

Target: 127.0.0.1 | Severity: Info | Risk score: 2.3/10 (low)

CWE: CWE-200 | MITRE ATT&CK: T1598

Un fichier .well-known/security.txt est publiquement accessible et contient une adresse de contact (mailto:donotreply@owasp-juice.shop). Cette information, bien que faiblement sensible, confirme l'organisation proprietaire de la cible et peut alimenter des campagnes de phishing ou d'ingenierie sociale.

Remediation:

Verifier que l'adresse de contact publiee est une boite de service dediee et non une adresse exploitable, et limiter l'exposition de ce fichier aux environnements de production uniquement.

Command used:

```
nuclei -target 127.0.0.1:3000 -severity info,low,medium,high,critical -jsonl -silent -etags dos,intrusive
```

Evidence (source excerpt): "extracted-results":[" mailto:donotreply@owasp-juice.shop"]

Remediation Priorities

No findings retained for this report.